

COLLEGE FOOTBALL FANTASY

Authentication, Authorization & Security Requirements

Revised for TRD & Backlog

Project	College Football Fantasy — Team 4
Sprint	Sprint 1 — Foundation
Owner Function	Cybersecurity
Product Manager	Aliyu Muhammed
Version	1.1
Date	September 2026
Status	Revised for Team Review

1. Objective

Define the minimum security controls required to protect user accounts, permissions, fantasy teams, leagues, lineup and waiver actions, game scores, rankings, APIs, administrative functions, secrets, and game data.

2. Authentication Requirements

MVP — Mandatory

- Users must authenticate before accessing protected resources.
- Passwords must never be stored in plaintext and must use secure password hashing.
- Authentication must use HTTPS/TLS.
- Tokens/sessions must have expiry and validation.
- Invalid or expired tokens must be rejected.
- Login and password-reset endpoints must have rate limiting.
- Password-reset mechanisms must use secure, time-limited tokens.
- Logout/session invalidation must be supported.

Future Enhancement

- Multi-factor authentication (MFA).
- Adaptive/risk-based authentication.
- Device/session management.

3. Authorization Requirements

MVP — Mandatory

- Authorization must be enforced on the backend.
- Users must only access resources they are authorized to access.
- Users must not access another user's private fantasy-team or account data.
- Administrative functions must require appropriate privileges.
- Authorization must follow deny-by-default.
- Frontend restrictions must not be treated as security controls.
- Every protected API endpoint must have an authorization check.

Future Enhancement

- Fine-grained permission management.
- Conditional or temporary permissions.

4. Role-Based Access Control (RBAC)

MVP — Mandatory

- **Player/User:** manage own profile, fantasy team, league participation and permitted game actions.
- **League Manager:** manage permitted league settings and membership.
- **Admin:** manage users, roles, leagues and approved administrative functions.
- **Service Account:** perform only specifically authorized application/service functions.
- Users must not receive unnecessary privileges or assign themselves higher privileges.
- Role changes must be restricted and auditable.

Future Enhancement

- More granular permissions, custom league roles and advanced permission policies.

5. API Security Requirements

MVP — Mandatory

- Production API traffic must use HTTPS/TLS.
- Protected endpoints must require valid authentication and authorization.
- API requests must be validated server-side.
- Sensitive endpoints must have appropriate rate limiting.
- API errors must not expose passwords, tokens, stack traces or sensitive system information.
- Sensitive information must not be unnecessarily returned.
- CORS must be restricted to approved origins.
- Third-party API credentials must not be exposed in frontend code.

Future Enhancement

- Advanced API threat detection and gateway security policies.

6. Database Security

MVP — Mandatory

- PostgreSQL access must follow least privilege.
- Application services must not use database superuser accounts.
- Database credentials must be stored securely.
- Queries must use parameterized queries or a secure ORM.
- Production and development credentials must be separated.
- Database backups must be protected.

Future Enhancement

- Advanced database activity monitoring and automated security scanning.

7. Protection of User Accounts & Game Data

MVP — Mandatory

- User account information must be protected from unauthorized access.
- Fantasy-team data must only be accessible to authorized users.
- Player and college-team data must be validated before use.
- Clients must not be trusted to submit authoritative scores.
- Users must not directly modify official player statistics.
- Backend services must control scoring and ranking calculations.
- Game-critical data must have controlled update paths.
- Sensitive user information must follow data-minimization principles.

8. Secure Lineup & Waiver Actions

MVP — Mandatory

- Lineup changes must require authentication.
- The backend must verify that the user owns or controls the fantasy team.
- Lineup actions must be validated against current gameweek rules.
- Waiver requests must be authorized server-side.
- Unauthorized modification of another user's lineup must be prevented.
- Applicable deadlines and roster rules must be enforced.

- Important lineup/waiver actions should be recorded for audit.

Future Enhancement

- Advanced anomaly detection and enhanced dispute/audit tools.

9. Anti-Cheating Requirements

MVP — Mandatory

- Users must not manipulate fantasy scores through API requests.
- Client-submitted scores/rankings must not be authoritative.
- Scoring must be calculated or verified by trusted backend services.
- Duplicate/replayed game-data processing must be controlled.
- Critical scoring-rule changes must require authorization.
- Suspicious security/game-integrity events should be logged.

Future Enhancement

- Automated cheating detection and behavioral anomaly detection.

10. League Integrity

MVP — Mandatory

- Only authorized users can create or manage leagues.
- League membership must be controlled.
- League settings must only be changed by authorized users.
- Users must not manipulate another league's settings.
- League standings must be calculated by trusted backend logic.
- League scores/rankings must not be directly editable by players.
- Important league-management actions should be auditable.

Future Enhancement

- Automated collusion detection and advanced league-abuse monitoring.

11. Secrets Management

MVP — Mandatory

- API keys, database passwords and signing secrets must not be committed to source control.
- Secrets must be securely stored and separated by environment.
- Secrets must not appear in application logs.
- Access to secrets must follow least privilege.
- Compromised credentials must be rotated.

Future Enhancement

- Dedicated cloud secrets management, automated rotation and repository scanning.

12. Logging & Monitoring

MVP — Mandatory

- Log successful/failed logins, password resets, authorization failures and role changes.
- Log relevant administrative actions and sensitive lineup/waiver actions.
- Log important scoring/ranking changes and suspicious API activity.
- Passwords, tokens and secrets must never be logged.

- Logs must be protected against unauthorized modification.

Future Enhancement

- Centralized SIEM, automated security alerts and real-time dashboards.

13. Scoring & Game Integrity

MVP — Mandatory

- The backend must be the authoritative source for fantasy scores.
- Players must not directly modify scores.
- Player statistics must come from approved/trusted data sources.
- Scoring and ranking calculations must be validated.
- Critical scoring changes must require authorization.
- Game-critical operations must be auditable.

Future Enhancement

- Automated scoring anomaly detection and advanced integrity analytics.

14. Security Testing

MVP — Mandatory

- Test authentication, authorization and RBAC.
- Test privilege escalation and unauthorized resource access.
- Test API validation and rate limiting.
- Test session/token security.
- Test secrets exposure and database access controls.
- Test lineup/waiver authorization.
- Test score/ranking manipulation and common injection vulnerabilities.

Future Enhancement

- Automated penetration testing and continuous security testing in CI/CD.

15. MVP Security Requirements Summary

SEC-001 Secure authentication — MVP

SEC-002 Secure password storage — MVP

SEC-003 Token/session validation — MVP

SEC-004 Backend authorization — MVP

SEC-005 RBAC — MVP

SEC-006 Resource ownership checks — MVP

SEC-007 API security and validation — MVP

SEC-008 Rate limiting — MVP

SEC-009 Database least privilege — MVP

SEC-010 Secure secrets management — MVP

SEC-011 User-account protection — MVP

SEC-012 Lineup/waiver authorization — MVP

SEC-013 Anti-cheating/scoring integrity — MVP

SEC-014 League integrity — MVP

SEC-015 Security logging — MVP

16. Future Security Enhancements

- MFA.
- Advanced anti-cheating and behavioral anomaly detection.
- Automated collusion detection.
- Centralized SIEM and real-time security dashboards.
- Automated secret rotation and repository scanning.
- Advanced API threat detection.
- Continuous penetration testing.

17. Implementation Priority

Priority 1 — Foundation: authentication, backend authorization, RBAC, token/session security, secrets management, API validation and rate limiting.

Priority 2 — Data & Integrity: database least privilege, resource ownership, scoring/ranking integrity and audit logging.

Priority 3 — Hardening: security testing, vulnerability scanning, monitoring, alerting and incident-response preparation.

18. Final Acceptance Criteria

- Protected resources require valid authentication.
- Invalid/expired/tampered tokens are rejected.
- Backend authorization prevents unauthorized access.
- Users cannot access another user's protected resources.
- Administrative actions require appropriate privileges.
- Passwords are securely hashed.
- Sensitive APIs have appropriate rate limiting.
- Secrets are not hard-coded or exposed in source control.
- Database access follows least privilege.
- Lineup and waiver actions are authorized.
- Players cannot directly manipulate scores/rankings.
- League-management actions are protected.
- Security/game-integrity events are logged.
- Security testing has been performed.

19. Conclusion

The MVP should prioritize strong access control, secure authentication, API protection, data protection, lineup/waiver security, anti-cheating controls, league integrity and security logging. Advanced capabilities can remain in the TRD backlog as future enhancements without unnecessarily blocking the MVP.